

Business Associate Agreement

1. Business Associate Obligations

1. Obligations and Restrictions. Provider

may not use or disclose PHI other than as described in this BAA, as permitted under the Privacy Rule, or as otherwise required by applicable law.

2. Permitted Uses and Disclosures. Provider

Except as otherwise permitted or required in this BAA, Provider may only use or disclose PHI as reasonably necessary to provide the Services or as otherwise required by applicable law.

3. Privacy and Information Security Program. Provider

Provider will maintain a privacy and information security program that takes steps to ensure that employees or agents of Provider comply with this BAA. This includes giving training to Provider's workforce to ensure compliance with this BAA, implementing policies and practices that meet the current standards for the protection of PHI, and appointing Privacy and Security Officials as required under HIPAA.

4. Safeguards. Provider

Provider will implement appropriate administrative, physical, and technical safeguards to protect the confidentiality, integrity, and availability of PHI that it receives, creates, maintains, or transmits on behalf of Company. Provider will maintain appropriate technical and organizational safeguards to reduce the risk of misuse or disclosure of PHI except as permitted under this BAA. In addition, Provider will comply with its obligations under the Security Rule.

5. Assessments. Provider

Provider agrees to conduct regular assessments of its compliance with its obligations under the Privacy Rule and Security Rule. Provider will make available a summary of such assessments to Company upon Company's reasonable request.

6. Mitigation of Risks. Provider

Provider agrees to mitigate, to the extent practicable, any harmful effect that is known to Provider of a use or disclosure of PHI by Provider and to promptly communicate to Company any actions taken pursuant to this paragraph.

7. Subcontractors. Limitations

Except as restricted by applicable Limitations, (a) Provider may disclose PHI to a Subcontractor; and (b) may allow the Subcontractor to create, receive, maintain, or transmit PHI on its behalf. However, Provider must first ensure that each Subcontractor executes a binding, written agreement requiring the Subcontractor to protect PHI under terms substantially similar to and no less stringent than this BAA. Provider will not be in compliance with this BAA if Provider knew of a pattern of activity or practice of a Subcontractor that constituted a material breach or violation of the Subcontractor's obligations under any agreement between Provider and the Subcontractor. Provider will conduct appropriate due diligence on all Subcontractors.

8. Books and Records to HHS. Provider

Upon request, Provider

Provider will make its books, records, and internal policies and procedures relating to the use and disclosure of PHI available to the Secretary of HHS for the purpose of determining Company's and Provider's compliance with HIPAA.

9. **Audit of Books and Records.** Upon reasonable request, Provider will make its books, records, and internal policies and procedures relating to its compliance with this BAA available to Company. However, Provider is not required to provide any information or records that interfere with Provider's confidentiality or proprietary rights or that would otherwise impact Provider's compliance with its legal obligations.

10. **Individual Requests.** Provider will take reasonable efforts to support Company in completing requests related to individuals' rights under HIPAA as related to the Services in a timely manner, but in no event will Provider's response take more than ten business days. Examples of individual rights under HIPAA include the right to access PHI pursuant to 45 CFR §164.524, amend PHI pursuant to 45 CFR §164.526, and receive accounting of disclosures pursuant to 45 CFR §164.528. If relevant to the Services, Provider will maintain an accounting of disclosures it makes on Company's behalf as required under 45 CFR §164.528(a). Except as directed by Company or required by law, Provider will not respond directly to any individual requests regarding their rights under HIPAA.

11. **Compliance with Covered Entity's Obligations.** To the extent that Provider carries out Company's obligations under the Privacy Rule, Provider will comply with the requirements of the relevant Privacy Rule regulations that apply to Company in the performance of such obligations.

2. **Company Obligations**

1. **Notice of Privacy Practices.** Upon request, Company will provide Provider with its current notice of privacy practices adopted as required by the Privacy Rule. Company will notify Provider if any limitations in its notice of privacy practices impact Provider's use or disclosure of PHI under the BAA.

2. **Notice of Changes.** Company will notify Provider in a timely manner of any changes to how Company uses or discloses PHI to the extent that the changes impact how Provider uses or discloses PHI under the BAA.

3. **Notice of Restrictions.** Company will notify Provider in a timely manner of any restrictions agreed upon with an individual or their legal representative to the extent that the restrictions may impact Provider's use or disclosure of PHI under the BAA.

4. **Compliance with Laws.** Provider

Company will only use and disclose PHI to Provider in accordance with its obligations under HIPAA and with applicable law.

3. Data Rights & Restrictions

1. Offshoring PHI. Except as restricted by applicable Limitations, Provider is permitted to use and disclose PHI outside of the United States to provide the Services.

2. De-Identification. Except as restricted by applicable Limitations, Provider may de-identify PHI.

3. Aggregation. Except as restricted by applicable Limitations, Provider may aggregate PHI for its own purposes.

4. Breach Notification

1. Breach Reporting. Provider will report to Company within the Breach Notification Period each use or disclosure of PHI not permitted under this BAA of which Provider becomes aware, including breaches of unsecured PHI as required by §164.410 of HIPAA and any Security Incident involving PHI. In addition, each party will comply with its notification obligations under HIPAA regarding a Security Incident involving PHI.

2. Unsuccessful Attempts. Company agrees that this section will be deemed as sufficient notice under Section 4.1 if Provider periodically receives unsuccessful attempts for unauthorized access to, use of, or disclosure of PHI, or for general interference with the general operation of Provider's products and services.

3. Security Incident Reimbursement. Provider will reimburse Company for costs reasonably associated with a Security Incident caused by Provider or one of its Subcontractors.

4. Confidentiality. Provider will not disclose information related to a Security Incident except as required by applicable law.

5. Term & Termination

1. Term. This BAA will start on the BAA Effective Date and will continue in effect until the later of when all obligations of the parties have been met under this BAA or when the Agreement ends or expires.

2. Termination. Either party may terminate this BAA if the other party fails to cure a material breach of the BAA within 30 days after receiving notice of the breach. A material breach of the BAA will be deemed a material breach of the Agreement.

3. Effect of Termination.

a. Upon any expiration or termination of this BAA, or earlier if directed by Company, Provider will either return or destroy, at Company's discretion and according to Company's instructions, all PHI maintained in any form

by Provider, its agents, or its Subcontractors.

b. Provider may not retain any copies of PHI unless directed to do so by Company. However, if neither return nor destruction are feasible, Provider may retain PHI as long as Provider continues to comply with all provisions of this BAA for the time it retains PHI and limits the use or disclosure of retained PHI to those purposes that made the return or destruction of PHI infeasible.

6. Definitions

1. Defining Variables. Variables have the meanings or descriptions given on the Cover Page. However, if the Cover Page omits or does not define a Variable, the default meaning will be "none" or "not applicable" and the correlating clause, sentence, or section does not apply to the BAA.
2. "BAA" means the Cover Page between Provider and Company that incorporates these BAA Standard Terms and any policies and documents referenced in or attached to the Cover Page.
3. "BAA Standard Terms" means these Common Paper BAA Standard Terms Version 1.0, which are posted at <https://commonpaper.com/standards/business-associate-agreement/1.0>.
4. "Breach" has the meaning given to it under HIPAA.
5. "Business Associate" has the meaning given to it under HIPAA.
6. "Covered Entity" has the meaning given to it under HIPAA.
7. "Cover Page" means a document that is signed by the parties, identifies Provider and Company, incorporates these BAA Standard Terms, and includes definitions or descriptions for Variables.
8. "Designated Record Set" has the meaning given to it under HIPAA.
9. "HHS" means the U.S. Department of Health and Human Services.
10. "HIPAA" means the Health Insurance Portability and Accountability Act of 1996 and the rules and regulations thereunder, as amended from time to time.
11. "Privacy and Security Officials" has the meaning given to it under HIPAA.
12. "Privacy Rule" means the federal privacy regulations issued pursuant to HIPAA, codified at 45 CFR Parts 160 and 164 (Subparts A & E).
13. "Protected Health Information" or "PHI" has the meaning given to it under HIPAA.
14. "Security Incident" has the meaning given to it under HIPAA.
15. "Security Rule" means the federal security regulations issued pursuant to HIPAA, codified at 45 CFR Parts 160 and 164 (Subparts A & C).
16. "Services" means the products and services provided by Provider under the Agreement.
17. "Subcontractor" means a third party to whom Provider provides PHI under this BAA.
18. "Variable" means a word or phrase in the BAA Standard Terms that is highlighted and capitalized, such as Limitations.